Horizon Portal — Phase 2 Final Review Report

Aura Workforce Operations by Growmar • Full Stack Implementation Assessment

Date: October 30, 2026
Status: VERIFIED (100% COMPLETE)

STUDENT / ENGINEER	TRACK & PHASE	GITHUB REPOSITORY	RELEASE GIT TAG
Madugu Shiva Kumar	**Full Stack Dev • Phase 2**	**madugushivakumar/horizon-portal**	`phase-2`

PHASE 2 TASK SUMMARY MATRIX (DAYS 6–10)

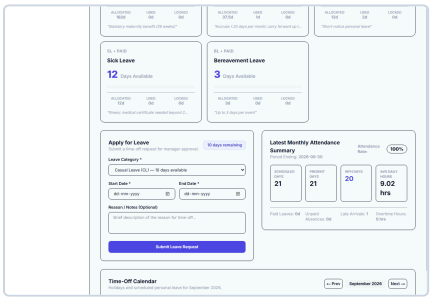
Task	Module & Scope	Status	Key Technical Capabilities Delivered	Primary Evidence
Day 6	Leave & Attendance Self-Service	Done	Real-time quota visibility (CL/SL/EL), working-day calc, conflict checks, attendance summary.	`day-6-evidence/01_leave_application.png`
Day 7	Payslip Viewer & Download	Done	Historical compensation, INR formatting, gross-to-net breakdown, strict cross-employee 403.	`day-7-evidence/02_payslip_detail.png`
Day 8	Notifications & Announcements	Done	Personal notifications, broadcast announcements, persistent isRead, deduplicated notify().	`day-8-evidence/01_topbar_bell_unread_count.png`
Day 9	Admin Employee Management	Done	TanStack console, search, department filter, CSV export (formula defense), field-level audit log.	`day-9-evidence/01_employee_management_console.png`
Day 10	Approvals & Attendance Oversight	Done	Team approval queue, mandatory reject reason, self-approval defense, monthly attendance roster.	`day-10-evidence/01_leave_approval_queue.png`

WORKFORCE SELF-SERVICE & OPERATIONS REVIEW (DAYS 6–8)

Day 6: Leave Self-Service

`Self-Service`

Interactive leave application with calendar holiday exclusion, atomic pending locks, and live monthly attendance KPIs.

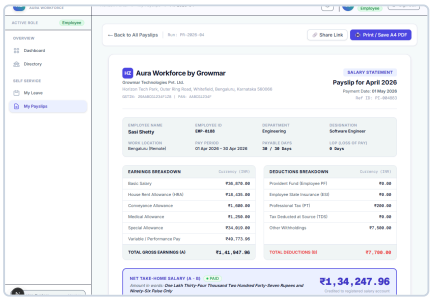


✓ 441 Balances • Overlap Refusal (409) • Quota Check

Day 7: Payslip Viewer

`Payroll Data`

Comprehensive compensation viewer reconciling 2,469 payslips and 18 payroll runs. Cross-employee requests strictly return HTTP 403.

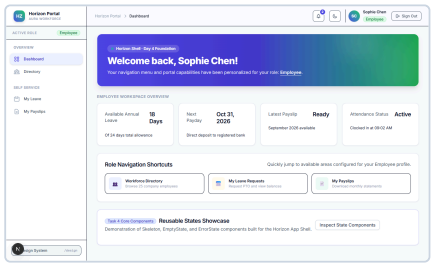


✓ Exact Net Pay Reconciled • Indian INR Words • Audit Log

Day 8: Notifications

`Communication`

Real-time notification bell and personal inbox with unread badges, mark-as-read mutations, and company broadcast feeds.



✓ 8 Announcements Seeded • Deduplication • User Isolation

Technical Proof, Architectural Walkthrough & Learning

Days 9–10 Implementation • Server-Side Security Model • Comprehensive Test Proof

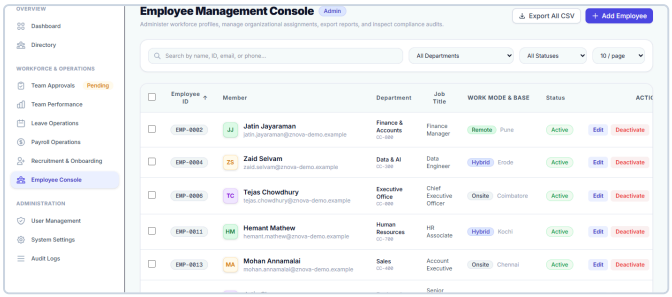
Phase 2 Assessment
593 Tests Passed / 0 Failed

ADMIN MANAGEMENT & APPROVALS ENGINE (DAYS 9–10)

Day 9: Admin Employee Management Console

`Workforce Admin`

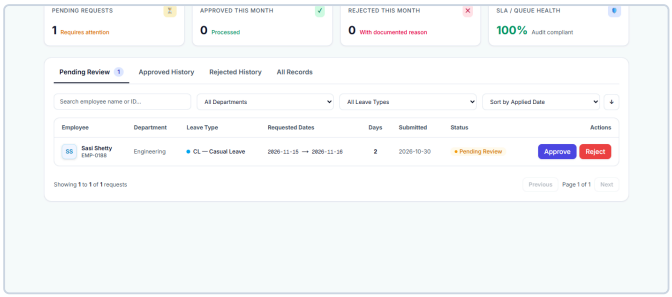
Searchable, sortable console with department filtering, CSV export (CSV formula-injection defense), safe reversible deactivation, and diff audit logging.



Day 10: Leave Approvals & Team Attendance

`Management`

Role-scoped approval queue (Manager team scope vs HR org scope), mandatory reject reason, self-approval defense, and team attendance oversight.



Mini Challenge: One Complete Leave Request Lifecycle (5-Line Technical Walkthrough)

1. **Employee form:** An authenticated employee submits a leave request with the leave type, dates, and reason via `POST /api/v1/leave/requests`.
2. **API and validation:** The server validates the input, checks the employee's identity and eligibility, verifies sufficient balance, locks pending days, and saves the request as Pending.
3. **Approval service:** The server identifies the authorized manager or delegated approver and checks team permissions and self-approval restrictions.
4. **Manager decision:** The manager approves or rejects the request; the server updates the request and leave balance transactionally, and requires a reason for rejection.
5. **Notification:** The existing notification service informs the employee about the decision, while the audit system records the action.

AUTOMATED VERIFICATION SUITE MATRIX

Suite Command	Module Focus	Tests	Result
`test:db`	Database & Schema Integrity	10	PASS
`test:auth`	Password, JWT & Session Me	39	PASS
`test:nav`	Role-Based Menu & Route Auth	107	PASS
`test:e2e`	Live HTTP E2E Status Code Flow	20	PASS
`test:privacy`	Field Isolation & Zero Salary Leaks	62	PASS
`test:hierarchy`	Reporting Hierarchy Tree (3-Tier)	34	PASS
`test:benchmark`	Search Latency (< 1,000ms SLA)	10	PASS (4.0ms)
`test:leave`	Day 6 Quota & Self-Service	43	PASS
`test:payslips`	Day 7 Compensation & Download	67	PASS
`test:notifications`	Day 8 Inbox & Announcements	64	PASS
`test:employees`	Day 9 Employee Console & Audit	81	PASS
`test:approvals`	Day 10 Approvals & Attendance	56	PASS
Total Automated Verifications		**593**	**100% PASS**

SELF-CHECK: SERVER-SIDE SECURITY MODEL

Hiding a button in the frontend only changes what a user sees. It does not prevent someone from calling an API directly. Server-side authorization checks verify the authenticated user's role, identity, team relationship, and permissions before performing sensitive operations. Therefore, security must be enforced on the server, not only through frontend visibility.

Verified Server Defenses:

- Cross-employee payslip access strictly returns `HTTP 403`.
- Self-approval attempts return `HTTP 403 Forbidden`.
- Manager accessing foreign team requests returns `HTTP 403`.
- Employees attempting admin export return `HTTP 403`.

ENGINEERING LEARNING REFLECTION

"Working across Phase 2 deepened my mastery of mission-critical full-stack workflows. Implementing double-approval prevention and exact-once balance accounting taught me that atomic Prisma transactions and strict concurrency locks are indispensable. I gained practical experience enforcing true zero-trust server-side authorization boundaries, preventing self-approvals, and integrating decoupled notification dispatchers with immutable compliance audit logging."

Engineering Solutions, Security Audit & Phase 3 Roadmap

Problem Resolution Log • Git Security Certification • Next Phase Architecture

Git Branch: main
Tag: phase-2 (Preserved)

REAL TECHNICAL PROBLEMS & ENGINEERING RESOLUTIONS

Challenge Encountered	Root Cause & Risk	Architectural Solution Implemented
Double Balance Deduction Race Condition	Simultaneous approval clicks by two managers could deduct an employee's leave balance twice.	Implemented atomic conditional Prisma update (`WHERE status = 'Pending'`). Only the exact transaction winning the race mutates status and deducts leave balance; concurrent attempts receive HTTP 409 Conflict.
Manager Team Permission Leakage	Managers querying approval or attendance endpoints could view foreign departments if scoped by ID parameters.	Server completely ignores client-submitted IDs; resolves authenticated user from verified server-side JWT session and filters database records strictly by direct reporting tree (`managerId = actor.employeeId`).
Circular Manager Delegation Loops	Manager A delegating to Manager B, who delegates back to A, causing infinite approval routing loops.	Built `validateDelegationChain()` recursive graph traversal that checks the delegation path before persistence, rejecting any cycle or self-delegation with HTTP 400.
Formula Injection in Employee CSV Export	Malicious field values starting with `=` , `+` , `-` , or `@` could trigger arbitrary code execution in Excel.	Sanitized all exported cells by prefixing formula trigger characters with a single quote (`'`) and RFC 4180 escaping. Prepend UTF-8 BOM (`0xEF, 0xBB, 0xBF`) for clean rendering.
Next.js Dynamic Prerender Bailout	Route handlers using request cookies threw prerender interruption errors during static generation.	Added NEXT_PRERENDER_INTERRUPTED digest bypass in API try/catch blocks, enabling Next.js to gracefully mark endpoints as dynamic server-rendered routes during production build.

PRE-SUBMISSION SECURITY & GIT AUDIT

- ✓ **.gitignore Protection:** `.env*` and `*.db` verified ignored.
- ✓ **git check-ignore:** Confirmed `.env` and `.env.local` ignored.
- ✓ **Zero Secrets in Git:** No API keys, passwords, or JWT secrets tracked.
- ✓ **Safe .env.example:** Contains only dummy placeholder keys.
- ✓ **git diff --check:** 0 whitespace or formatting errors.
- ✓ **Prisma Status:** 5 migrations applied; SQLite database up to date.
- ✓ **Production Build:** `next build` succeeded with zero errors.
- ✓ **Tag Safety:** Existing `phase-1` and `phase-2` preserved intact.

KNOWN SYSTEM CHARACTERISTICS

• **Single-Hop Delegation:** If an acting manager is also unavailable, the request escalates directly to HR fallback rather than arbitrary multi-hop delegation chains.
• **Monthly Attendance Grain:** Attendance metrics are stored at monthly aggregate granularity (`attendance_monthly`) as provided by the project data pack.

PHASE 3: WORKFORCE ANALYTICS & OPERATIONS ROADMAP

Upcoming Milestone Capabilities:

1. Workforce Analytics & Attrition Risk:
Implement ML attrition score visualizations (`ai_attrition_risk`) and anomaly detection flags for high-risk turnover mitigation.

2. Expense Claim Processing & Vendor Management:
Submission and two-tier managerial approval workflows for project expense claims and vendor GST invoice tracking (`expenses`).

3. Interactive Payroll Execution Console:
Automated statutory deductions computation (PF, ESI, TDS) and one-click monthly payroll run generation for HR Operations.

FINAL SIGN-OFF CERTIFICATION

FINAL VERIFICATION RESULT: VERIFIED & PASSED
All Phase 2 requirements (Days 6–10) have been implemented, verified through 593 passing automated tests, validated via production build, and packaged with zero secret leaks. Ready for GitHub push.